

# CISO–DPO JOINT GOVERNANCE CHARTER

*Security and Privacy Governance Collaboration Framework*

Document Classification: Internal – Executive Governance | Version 1.0 | Effective Date: Upon Executive Approval

## 1. Purpose

Cybersecurity and data privacy have become two sides of the same governance coin. A control failure in one nearly always creates exposure in the other. Yet, in most organisations, the CISO and DPO still operate from separate mandates, separate reporting lines, and separate risk registers. This charter closes that gap. It establishes a single, formal framework through which the Chief Information Security Officer and the Data Protection Officer jointly govern the technology, data, and vendor decisions that carry both security and privacy implications.

The rationale is straightforward. Regulators increasingly expect organisations to demonstrate that security and privacy controls are designed together, not bolted on independently after the fact. Boards want one coherent risk narrative rather than two competing ones. And business units need a single point of engagement for initiatives that touch personal data, instead of navigating parallel approval tracks with inconsistent requirements. Formalizing CISO–DPO collaboration reduces duplication, shortens review cycles, and produces governance decisions that hold up under regulatory and board scrutiny.

This charter is binding on both functions and on any business unit initiating a project within its scope. It does not replace either function's underlying mandate — it defines how the two mandates operate together.

## 2. Scope

The following categories of initiative require mandatory joint CISO–DPO review before implementation. Business units are responsible for identifying when their initiative falls within scope and for initiating the review early enough that findings can influence design rather than force rework.

- New applications or systems that collect, process, or store personal data.
- Cloud migrations involving personal data, including SaaS adoption and infrastructure re-platforming
- AI and machine learning initiatives that use personal data for training, inference, or profiling
- Onboarding of third parties and vendors with access to personal data or connected systems
- Cross-border data transfers, including intra-group transfers between jurisdictions
- Major technology changes affecting data flows, network architecture, or identity and access management
- Data retention and deletion initiatives, including archiving and records disposition projects
- Data Protection Impact Assessments (DPIAs) classified as high-risk
- Security architecture changes with direct impact on systems holding personal data

## 3. Governance Principles

Seven principles anchor how the CISO and DPO exercise joint authority. They are deliberately practical rather than aspirational, and both functions are expected to apply them consistently in every review.

- Shared accountability — neither function approves a scoped initiative unilaterally; sign-off requires both.
- Risk-based decision making — the depth of review scales with the sensitivity of the data and the severity of potential harm.

- Privacy by Design — privacy requirements are built into architecture decisions, not retrofitted after deployment.
- Security by Design — technical controls are embedded from the design phase, not layered on as a compliance afterthought.
- Transparency — decisions, dissents, and rationale are documented and available for audit and regulatory review.
- Regulatory compliance — obligations under applicable data protection and security regulations are treated as a floor, not a ceiling.
- Business enablement — governance exists to make responsible innovation possible, not to obstruct it.

## 4. Roles and Responsibilities

Each function retains ownership of its domain. The table below sets out where CISO and DPO responsibilities are distinct and where they are exercised jointly.

| CISO Responsibilities                                             | DPO Responsibilities                                                       | Joint Responsibilities                                                        |
|-------------------------------------------------------------------|----------------------------------------------------------------------------|-------------------------------------------------------------------------------|
| Owns cybersecurity strategy, architecture, and technical controls | Owns privacy governance, regulatory interpretation, and compliance program | Conduct joint review of in-scope initiatives                                  |
| Manages information security risk register and control testing    | Leads DPIAs and manages data subject rights requests                       | Co-author executive and board risk reporting                                  |
| Directs technical incident response and forensic containment      | Assesses regulatory notification obligations and breach thresholds         | Coordinate incident response across security and privacy workstreams          |
| Owns vulnerability management, patching, and security monitoring  | Maintains records of processing and cross-border transfer mechanisms       | Approve or escalate vendor and third-party onboarding involving personal data |
| Sets security architecture standards and access control policy    | Sets privacy policy, consent standards, and retention schedules            | Maintain the joint governance risk log and meeting record                     |

## 5. Joint Review Process

The review process is designed to be predictable enough that project teams can plan around it, while remaining flexible enough to scale with risk.

### Review Triggers

A joint review is triggered automatically when a project is tagged, during intake, as falling within the scope defined in Section 2. Project and procurement intake forms include a mandatory screening question that routes qualifying initiatives to the joint review queue.

### Required Documentation

Initiators submit a project brief, a data flow diagram, a vendor security and privacy questionnaire (where applicable), and a preliminary risk classification. High-risk initiatives additionally require a draft DPIA and, where relevant, a security architecture review document.

## Review Workflow

Intake and triage occur within five business days of submission. The CISO and DPO conduct an initial joint assessment, request clarifications or additional controls where needed, and issue a decision. Standard reviews are targeted for completion within fifteen business days; high-risk reviews may take longer and are communicated to the initiator with a revised timeline.

## Decision-Making and Conflict Resolution

Approval requires consensus between the CISO and DPO. Where the two disagree on risk tolerance or required controls, the matter is escalated per Section 8 rather than resolved by either function overriding the other. Escalation is expected to be the exception, not the norm — most disagreements are resolved through direct discussion and reference to the governance principles in Section 3.

## Final Approval Authority

For standard and moderate-risk initiatives, joint CISO–DPO sign-off constitutes final approval. High-risk initiatives additionally require notation to the CIO and General Counsel, and initiatives with material regulatory or reputational exposure require Executive Leadership Team awareness before go-live.

## 6. Meeting Cadence

| Meeting                      | Attendees                                            | Objective                                                                        |
|------------------------------|------------------------------------------------------|----------------------------------------------------------------------------------|
| Weekly operational meeting   | CISO/DPO delegates, security and privacy leads       | Track open reviews, resolve routine questions, monitor incident status           |
| Monthly governance meeting   | CISO, DPO, senior security and privacy managers      | Review risk register, close out escalations, assess process performance          |
| Quarterly executive review   | CISO, DPO, CIO, General Counsel                      | Present integrated risk posture, review high-risk initiatives, adjust priorities |
| Annual governance assessment | CISO, DPO, Executive Leadership Team, Internal Audit | Assess charter effectiveness, benchmark maturity, approve amendments             |

## 7. Incident Response Coordination

Security incidents involving personal data follow a single coordinated workflow rather than two parallel ones. The phases below apply from the moment an incident is confirmed to affect, or potentially affect, personal data.

- **Detection** — the Security Operations Center identifies and logs the incident; the CISO is notified immediately and the DPO within one hour where personal data may be involved.
- **Containment** — the CISO leads technical containment; evidence preservation begins immediately, with chain of custody maintained for forensic and regulatory purposes.
- **Joint Assessment** — the CISO and DPO jointly assess scope, data categories affected, and number of individuals impacted within 24 hours of confirmation.

- **Regulatory Assessment** — the DPO leads the assessment of notification obligations under applicable data protection law, drawing on the CISO's technical findings; notification clocks are tracked from the point of confirmed awareness.
- **Executive Communication** — the CISO and DPO jointly brief the Executive Leadership Team; incidents meeting board notification thresholds — material financial, regulatory, or reputational impact — are escalated to the Board Risk Committee within 48 hours.
- **Recovery** — the CISO leads technical restoration; the DPO monitors for data subject communication obligations arising from the recovery process.
- **Post-Incident Review** — jointly conducted within ten business days of closure, producing a lessons-learned report and control remediation plan tracked to completion.

Throughout the incident, the CISO owns technical notification obligations to internal stakeholders and, where relevant, law enforcement; the DPO owns notification obligations to supervisory authorities and affected individuals. Evidence preservation standards follow the organization's digital forensics procedure regardless of which function initiates containment.

## 8. Escalation Path

Escalation follows a fixed hierarchy. Each level becomes involved only when the level below cannot resolve the matter within its authority or agreed timeframe.

- **Operational Teams** — handle day-to-day security and privacy tasks and routine review findings.
- **CISO + DPO** — resolve joint review decisions and standard incident coordination; this is where most matters are settled.
- **CIO and General Counsel** — engaged when CISO and DPO cannot reach consensus, or when an initiative carries material budget, legal, or contractual implications.
- **Executive Leadership Team** — engaged for enterprise-wide risk acceptance decisions or incidents with significant business impact.
- **Board Risk Committee** — engaged for incidents or decisions meeting board notification criteria, or where residual risk exceeds the organization's stated risk appetite.

## 9. Joint Board Reporting

The CISO and DPO submit a single integrated dashboard to the Board Risk Committee each quarter. Combining security and privacy metrics in one reporting artifact gives the board a coherent view of enterprise data risk, rather than two disconnected scorecards that obscure how a control gap in one domain drives exposure in the other.

| Security Metrics                     | Privacy Metrics                          |
|--------------------------------------|------------------------------------------|
| Number of security incidents         | DPIAs completed                          |
| Mean Time to Detect (MTTD)           | DSAR response performance                |
| Mean Time to Respond (MTTR)          | Vendor privacy assessments completed     |
| Critical vulnerabilities outstanding | Privacy incidents recorded               |
| Patch compliance rate                | Cross-border transfer reviews completed  |
| Phishing simulation results          | Regulatory inquiries received and status |

| Security Metrics | Privacy Metrics                           |
|------------------|-------------------------------------------|
| —                | Overall compliance status by jurisdiction |

Presenting these metrics side by side lets the board ask sharper questions — for example, whether rising DSAR volumes correlate with vulnerability trends in customer-facing systems, or whether vendor risk assessments are keeping pace with cloud adoption. That correlation is the entire point of joint governance: risk decisions made with full visibility across both domains, rather than in isolation.

## 10. Review and Approval

This charter is reviewed annually by the CISO and DPO jointly, with input from the CIO, General Counsel, and Internal Audit, and is reaffirmed or amended at the annual governance assessment described in Section 6. Interim amendments may be proposed by either function but require joint sign-off and notation to the Executive Leadership Team before taking effect.

Version history is maintained by the DPO's office as the designated document custodian, with the CISO's office retaining a mirrored copy. Formal approval authority rests with the Executive Leadership Team, with the Board Risk Committee holding oversight of the charter's continued adequacy.

### Approved by:

Chief Information Security Officer: \_\_\_\_\_ Date: \_\_\_\_\_

Data Protection Officer: \_\_\_\_\_ Date: \_\_\_\_\_

Executive Sponsor: \_\_\_\_\_ Date: \_\_\_\_\_